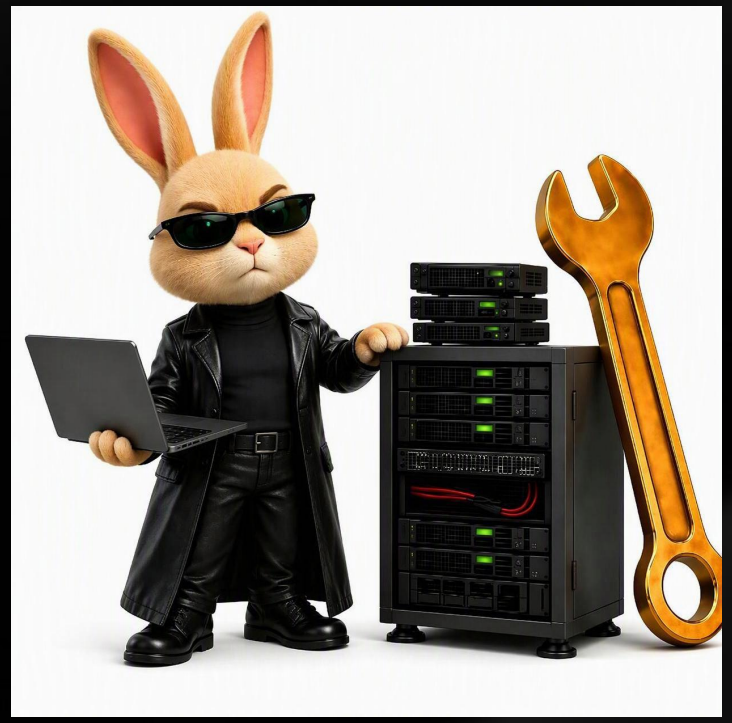


Breaking the Kill Chain

A Gamified Cyber Incident Recovery Masterclass

2026-10-13

Meet your incident team



Mikael Nyström



Hasain Alshakarti



Viktor Hedberg

@mikael_nystrom
https://deploymentbunny.com
https://www.truesec.com

MVP for 23 years
Incident Responder at Trusec CSIRT
Recover/Rebuild infrastructure







Hasain "The Wolf" Alshakarti
Principal Cyber Security Advisor
https://www.truesec.com

30+ years in security & infrastructure
16 years Enterprise Security MVP
Incident response, penetration testing, identity, PKI & network security



Microsoft MVP Most Valuable Professional

Viktor Hedberg
Senior Technical Architect
https://www.truesec.com

Microsoft Security MVP
Identity & Enterprise Security
Incident response & cloud forensics



Microsoft Most Valuable Professional

One-day training agenda

MORNING

08:30–09:00
Registration & Snacks

09:00–10:30
Masterclass

10:30–11:00
Break

11:00–12:00
Masterclass

12:00–12:45
Lunch

AFTER LUNCH

12:45–14:00
Masterclass

14:00–14:30
Break

14:30–16:00
Masterclass



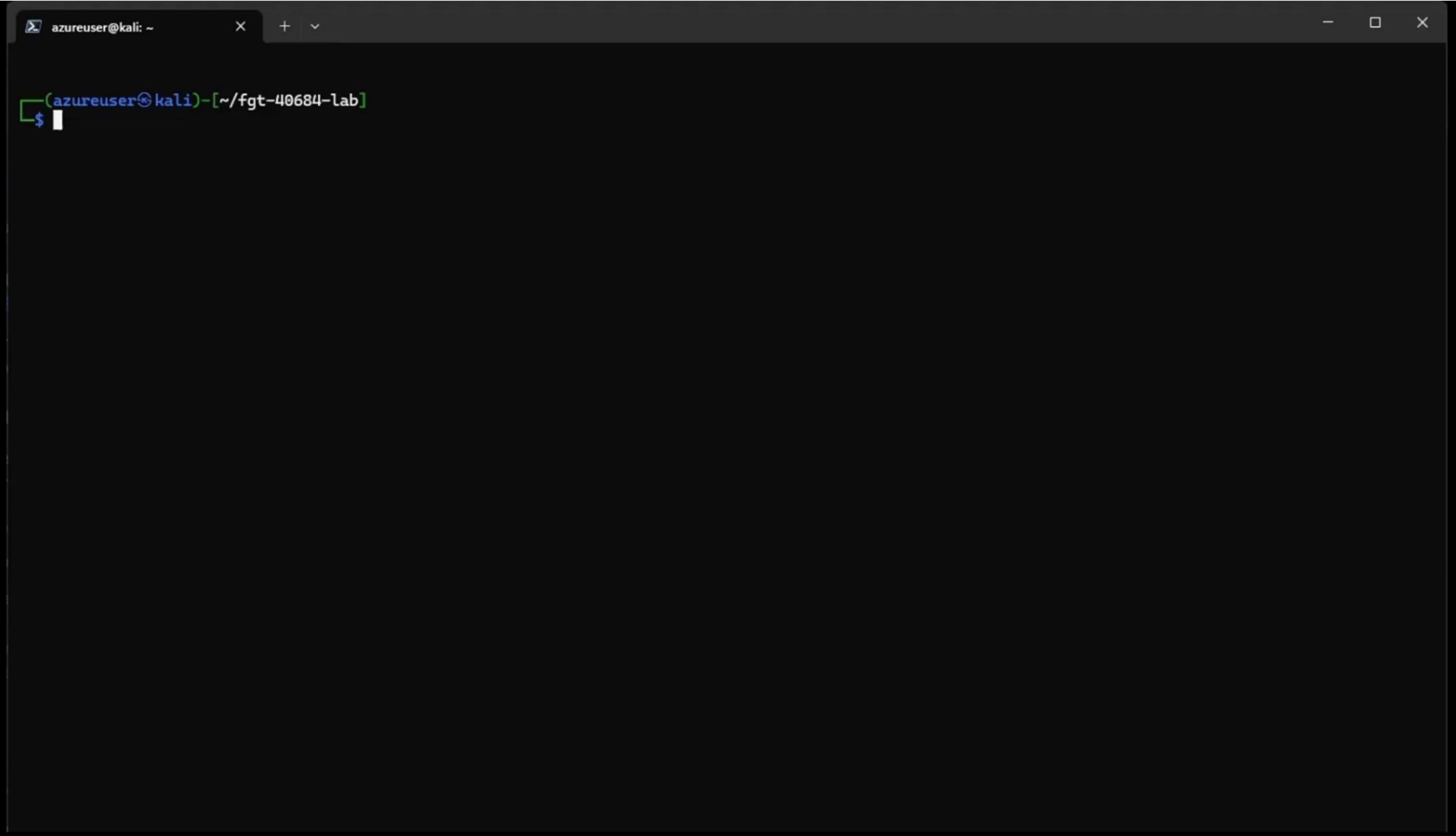
Scenario: When Attackers Go Agentic

ILLUSTRATIVE ATTACK SCENARIO

An actor uses AI to compare two firewall firmware versions and identify a possible security fix. A proof of concept tests the hypothesis on a lab firewall. After validation, the actor adapts it to target exposed, unpatched firewalls.

This is an illustrative chain, not a confirmed incident.




azureuser@kali: ~
(azureuser㉿kali)-[~/fgt-40684-lab]
$

Scenario: the forgotten VPN account

ILLUSTRATIVE ATTACK SCENARIO

VPN normally requires MFA, but an assumed policy exception leaves VPNtest / VPNTest usable without it. The actor connects to a flat server network and starts discovery.

From a local foothold, ARP poisoning may enable interception. Sniffing alone does not expose properly protected RDP passwords.



Scenario: the forgotten RDP exposure

ILLUSTRATIVE ATTACK SCENARIO

An internet-facing RDP service accepts Student1 / Student1. This grants only ordinary-user access. Assume a separate escalation later compromises the host.

During a monthly admin logon, reusable credentials may be exposed. A stolen NTLM hash could then support lateral movement through pass-the-hash.



Scenario: one consultant, many customers

ILLUSTRATIVE ATTACK SCENARIO

Phishing compromises a consultant’s laptop. The actor abuses available VPN sessions or credentials to enter customer environments as the consultant, wherever access controls allow it. The actor surveys those environments and selects targets.

One compromised device creates a potential incident across several customers.



Scenario: local admin, weakened protection

ILLUSTRATIVE ATTACK SCENARIO

A threat actor gains local administrator access and attempts to disable endpoint security. Where protections allow it, the actor can weaken defenses and reduce visibility.

Local admin does not automatically defeat every control. Tamper protection can block changes to protected settings.



```
rem WMIC /NAMESPACE:\\root\Microsoft\Windows\Defender PATH MSFT_MpPreference call Add ExclusionPath= xxxxxx

rem To disable System Guard Runtime Monitor Broker
rem reg add "HKLM\System\CurrentControlSet\Services\SgrmBroker" /v "Start" /t REG_DWORD /d "4" /f

rem To disable Windows Defender Security Center include this
rem reg add "HKLM\System\CurrentControlSet\Services\SecurityHealthService" /v "Start" /t REG_DWORD /d "4" /f

rem 1 - Disable Real-time protection
reg delete "HKLM\Software\Policies\Microsoft\Windows Defender" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender" /v "DisableAntiVirus" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\MpEngine" /v "MpEnablePus" /t REG_DWORD /d "0" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableBehaviorMonitoring" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableIOAVProtection" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableOnAccessProtection" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableRealtimeMonitoring" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableScanOnRealtimeEnable" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Reporting" /v "DisableEnhancedNotifications" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "DisableBlockAtFirstSeen" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "SpynetReporting" /t REG_DWORD /d "0" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "SubmitSamplesConsent" /t REG_DWORD /d "2" /f

rem 0 - Disable Logging
reg add "HKLM\System\CurrentControlSet\Control\WMI\Autologger\DefenderApiLogger" /v "Start" /t REG_DWORD /d "0" /f
reg add "HKLM\System\CurrentControlSet\Control\WMI\Autologger\DefenderAuditLogger" /v "Start" /t REG_DWORD /d "0" /f

rem Disable WD Tasks
schtasks /Change /TN "Microsoft\Windows\ExploitGuard\ExploitGuard MDM policy Refresh" /Disable
schtasks /Change /TN "Microsoft\Windows\Windows Defender\Windows Defender Cache Maintenance" /Disable
schtasks /Change /TN "Microsoft\Windows\Windows Defender\Windows Defender Cleanup" /Disable
schtasks /Change /TN "Microsoft\Windows\Windows Defender\Windows Defender Scheduled Scan" /Disable
schtasks /Change /TN "Microsoft\Windows\Windows Defender\Windows Defender Verification" /Disable

rem Disable WD systray icon
reg delete "HKLM\Software\Microsoft\Windows\CurrentVersion\Explorer\StartupApproved\Run" /v "SecurityHealth" /f
reg delete "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityHealth" /f

rem Remove WD context menu
```

Scenario: The art of stealing Active Directory secrets

ILLUSTRATIVE ATTACK SCENARIO

NTDSUtil backup / export

With sufficient privileges, an actor can abuse legitimate NTDSUtil exports to copy the AD database. Exposed copies can put domain password hashes at risk.

Backup

Stolen domain-controller backups can expose the same directory secrets without access to the live server. Backup access is part of the identity security boundary.

Windows Error Reporting

An actor with sufficient privileges may abuse error-reporting features to capture LSASS memory. This can expose available credentials, depending on system protections. It is not a copy of the AD database.

Or maybe, it is even easier than that...

THE INCIDENT BEGINS

08:17

Several users report that shared files are unavailable.

An administrator account has authenticated from an unexpected system.

Endpoint telemetry from one server stopped 47 minutes ago.

Nobody knows whether these events are related.

You are now the Incident Response Team.

From uncertainty to trusted recovery

Five questions, one operating principle, and a recovery process that does not reintroduce the attacker.

KNOW

Are we under attack?

ACT

What is the first action?

CONTAIN

How do we stop the threat actor?

ERADICATE

How do we remove the threat actor?

RECOVER

How do we rebuild the business?



Operating principle: assume breach until evidence proves otherwise.

KNOW: evidence and initial scope

Separate facts from hypotheses

Explain what each observation does and does not prove.

Establish a provisional scope

Identify affected assets and important visibility gaps.

Hand over a situation picture

Name the next decision and the evidence needed to support it.



REALITY

Incidents do not arrive in neat phases

Systems fail, facts conflict, and people start “fixing” things before the cause is known.

THE SYMPTOM

Outage, latency, missing data, strange authentication, unavailable services.

THE RISK

Normal troubleshooting changes the scene and may destroy evidence.

THE RESPONSE

Pause. Preserve. Triage as a suspected security incident.

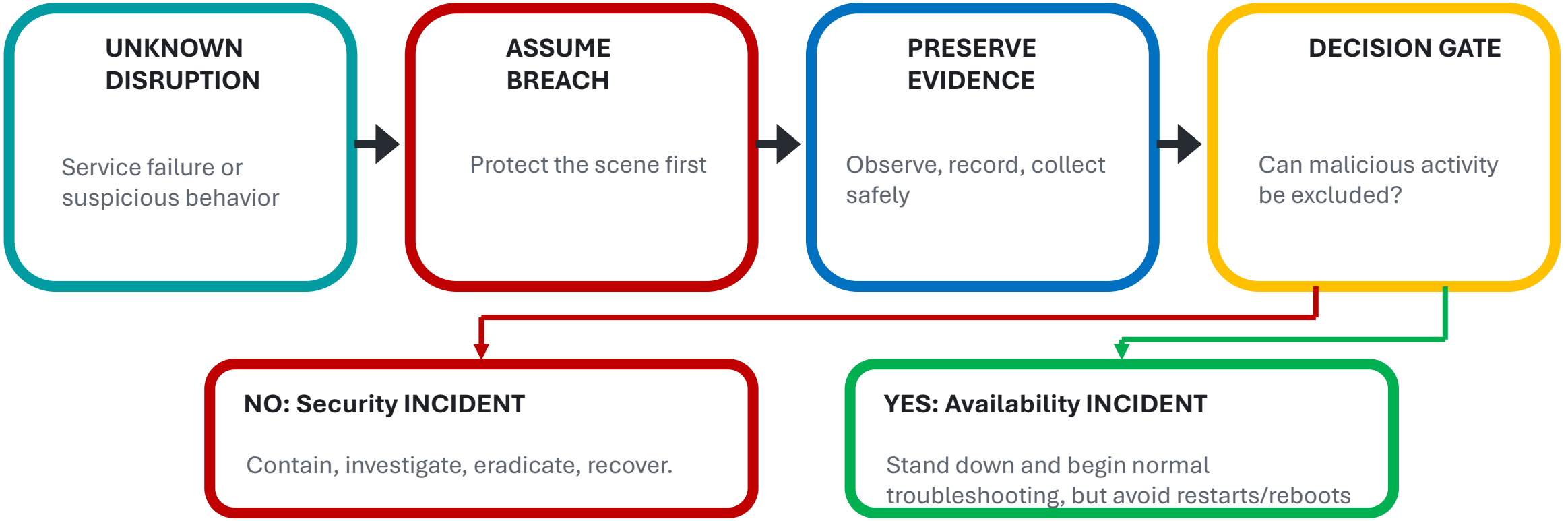


UNCERTAINTY IS NOT PERMISSION TO IMPROVISE

KNOW: ASSUME BREACH

Assume breach until proven otherwise

Classify the event as a suspected security incident while security triage is in progress.



KNOW: DETECTION

How do we know we are under attack?

No single alert proves a breach. Confidence comes from correlated signals across control planes.

IDENTITY

Impossible travel, token abuse, new privilege, disabled security control.

ENDPOINT

EDR alerts, execution chains, persistence, disabled agents.

NETWORK

Unexpected egress, scanning, lateral movement, C2 patterns.

DATA & BACKUP

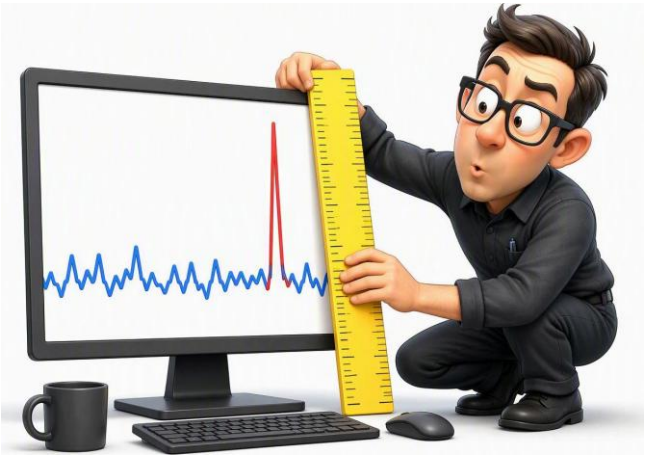
Bulk access, unusual encryption, deletion attempts, retention changes.

PEOPLE

User reports, ransom notes, unusual support requests, supplier warnings.

What is normal?

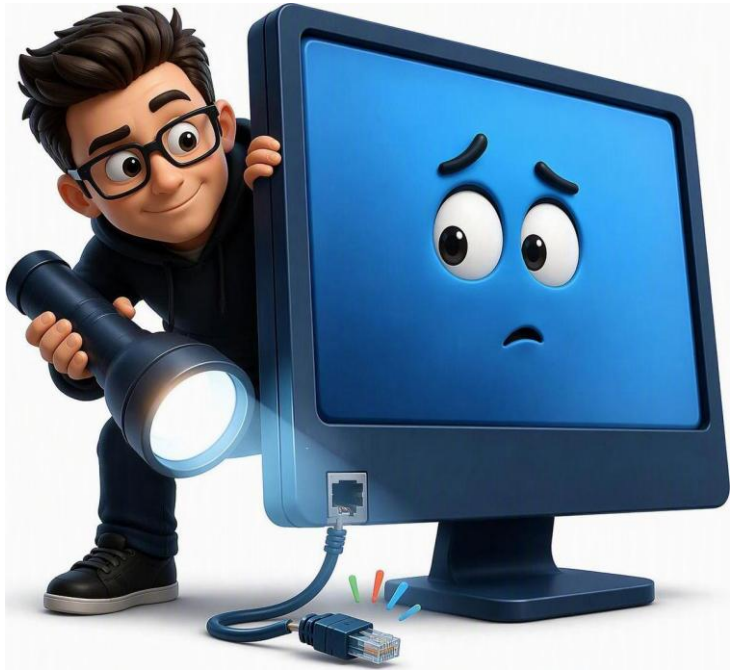
Create known baselines!



KNOW

Evidence, confidence and missing visibility

Observation	What it supports	What remains unknown
New privileged sign-in	An identity used a privileged access path	Who controlled the session
Endpoint detection	A tool observed suspicious behavior	Whether other hosts are affected
No events in a time window	No records in the source you searched	Whether collection or retention failed



KNOW: DETECTION

Software supply chain detection

Check software origin and behavior.

Supplier compromised?

Verify signatures and build provenance.
Check source and build changes.
Match supplier alerts to your versions.

Malicious package in our CI/CD?

Track dependencies and versions.
Inspect packages and install scripts.
Watch build traffic and secret access.



Signatures, SBOMs and clean scans cannot guarantee safe code.

KNOW: SITUATION PICTURE

One board. Four questions. Updated relentlessly.

WHAT DO WE KNOW?

Confirmed facts only
Timestamp + source

WHAT IS AT RISK?

People, services, data
Legal and financial exposure

WHAT ARE WE DOING?

Owner, action, deadline
Expected result

WHAT DECISION IS NEEDED?

Options, consequence
Decision owner



KNOW

Case briefing: an uncertain disruption

ILLUSTRATIVE TRAINING SCENARIO

Users report failed file access. An administrator sign-in looks unusual. Endpoint telemetry from one server has stopped.

No destructive activity is confirmed yet.

YOUR DECISION

Which observations are facts?

Which sources would you preserve first?

What would justify urgent containment?



DEMO: KNOW

Collecting information

Watch for evidence provenance, time alignment, scope and visibility gaps.

KNOW: the investigation toolbox

LogCollectionPack

ActiveDirectoryTools

CheckWindowsClientSecurityBaseline

Get-ADHealthCheck

Get-ReliabilityStabilityMetrics

Get-TSxManagmentIssues



https://github.com/DeploymentBunny/Files/tree/master/Tools

KNOW

Exercise: the initial situation report

ILLUSTRATIVE TRAINING SCENARIO

The unusual sign-in used an admin account. A deployment job explains some file errors. The missing endpoint telemetry remains unexplained.

YOUR DECISION

Draft a 30-second situation report.

State confirmed scope and unknowns.

Choose one next decision.



KNOW debrief: a defensible handover

FACTS

State what happened, when and which source supports it.

GAPS

Name what you cannot yet see and how that limits confidence.

NEXT DECISION

Assign the next action, its owner and an escalation trigger.



10:45–11:00

Break

Next: ACT. Bring your situation report.



ACT: authority and safe first response

BY THE END OF THIS HOUR

Create an accountable response

Assign incident authority and technical owners.

Protect the response environment

Choose trusted communications and administrative access.

Control emergency change

Record decisions, exceptions and review times.



ACT: PRESERVE EVIDENCE

Do not “fix” the system yet

- Restart, shut down, or fail over without an incident decision.
- Patch, update, reconfigure, or install and remove software.
- Delete files, clear logs, run cleanup tools, or overwrite virtual machines.
- Use ordinary administrator accounts or untrusted communication channels.



ALLOWED

Read and preserve existing logs. Document every action. Use approved forensic collection. Perform emergency containment only when authorized. Correlate with ITSM systems and tickets.

ACT: FIRST RESPONSE

Create control before creating change

The first technical action is not always the first organizational action.

DECLARE

Set suspected-incident status and appoint authority.

TRUST

Establish clean communications and clean administration.

PRESERVE

Protect evidence, logs, and the compromised environment.

PICTURE

Create one shared situation board with facts and owners.



If everybody can make changes, nobody can explain what happened.
Do not forget to get mandate!

ACT

Decision rights during the first response

Decision	Accountable owner	Record before or with action
Emergency containment	Incident authority	Expected harm, affected service, review time
Evidence collection	Forensic lead	Source, method, operator and storage location
Service workaround	Business owner with technical lead	Dependencies and accepted operational risk
External communication	Designated communications / legal lead	Verified facts, audience and approval



ACT

Trusted communication and administration

COORDINATION CHANNEL

Use an agreed out-of-band channel when normal communications may be monitored.

Verify participants and limit sensitive detail.

Keep one approved incident record.

ADMINISTRATIVE CHANNEL

Use a trusted device and approved emergency identity.

Check the access path before using privileged credentials.

Record every emergency exception.



ACT: INCIDENT COMMAND

Run two clocks at the same time

Technical truth and business survival move at different speeds.

INCIDENT COMMAND

Priorities, authority, risk acceptance, external coordination.

TECHNICAL RESPONSE

Evidence, containment, eradication, trusted recovery.

BUSINESS CONTINUITY

Critical processes, workarounds, customer impact, service order.

COMMUNICATIONS

Employees, customers, regulators, suppliers, media.



Be transparent

That doesn’t mean sharing EVERYTHING.

ACT

The emergency decision log

Field	Illustrative entry
Observation	Admin account activity requires investigation
Decision and rationale	Restrict the affected access path to reduce exposure
Owner and authority	Named responder, authorized by incident lead
Impact and evidence	Service dependencies checked; relevant logs retained
Review trigger	Reassess at the next update or on new evidence



DEMO: ACT

First response coordination

Authority and escalation, Trusted communication and access, Evidence and decision logging

ACT

Exercise: a request to reboot

ILLUSTRATIVE TRAINING SCENARIO

The service owner asks for an immediate reboot.
Security cannot yet explain the admin activity.
Operations reports growing business impact.

YOUR DECISION

Who can decide?

What alternatives could reduce harm?

What evidence and rationale must be recorded?



ACT

Exercise: unexpected outbound traffic

ILLUSTRATIVE TRAINING SCENARIO

A file server appears to be sending data to the internet. The team cannot yet confirm that it is backup traffic. The transfer continues.

YOUR DECISION

Can we block outbound internet access?

Only this server, or a wider scope?

Who can authorize it, and what must we record?



ACT

Exercise: an unexplained Domain Admin

ILLUSTRATIVE TRAINING SCENARIO

An account was added to Domain Admins. No one can explain why. It has been used on several computers. No other unusual activity has been reported, except that Advanced IP Scanner ran on one of them.

YOUR DECISION

What must we verify and preserve first?

Should we restrict the account or affected hosts?

Who can authorize this, and what must we record?



ACT

Exercise: missing logs and remote access

ILLUSTRATIVE TRAINING SCENARIO

Logs appear to have been deleted on several file servers. TeamViewer and AnyDesk are installed on one of them. We use both tools, but no one recognizes this installation. Should we uninstall them and reboot?

YOUR DECISION

What must we preserve before making changes?

Should we restrict remote access while we investigate?

Who can authorize removal or a reboot?



ACT

Exercise: unexpected Chrome installations

ILLUSTRATIVE TRAINING SCENARIO

Google Chrome appears to have been installed on several servers. No one recognizes or can explain the installations. Should we uninstall it and move on? Why would an attacker install a browser here?

YOUR DECISION

Who installed it, when, and under which account?

What was it used for, and what must we preserve?

Is removal enough, and who decides the next action?



ACT

Exercise: VPN access versus business impact

ILLUSTRATIVE TRAINING SCENARIO

Suspicious traffic appears to be coming through our VPN. Shutting it down could disrupt critical operations and affect gold prices worldwide. In this scenario, can we keep the VPN open while reducing the risk?

YOUR DECISION

Shutdown, MFA, or targeted restrictions?

If VPN stays open, which other controls are needed?

Who accepts the risk, and when must we reassess?



ACT debrief: control before change

AUTHORITY

A named decision-maker accepts the tradeoff.

SAFE EXECUTION

A trusted operator acts through an approved access path.

AUDIT TRAIL

The record explains evidence, impact and the next review.



12:00–12:45

Lunch

Next: Contain. The case continues after lunch.



CONTAIN

Contain: limiting harm and movement

BY THE END OF THIS HOUR

Select a containment scope

Balance affected access paths and business dependencies.

Protect critical control planes

Include identity, management and backup infrastructure.

Verify the effect

Check that the intended restriction actually holds.



CONTAIN

How do we contain the threat actor?

- Contain identities: revoke sessions, disable abused accounts, protect emergency access.
- Contain paths: block known infrastructure, restrict east-west movement, close exposed management.
- Contain systems: isolate selectively while preserving volatile and disk evidence.
- Island mode: keep critical systems running fully disconnected from other networks, even if compromised, pending remediation with approved risk acceptance.
- Contain change: freeze nonessential administration and record every exception.



KEY TRADEOFF

Contain too slowly and the attacker keeps moving. Contain blindly and the business may lose critical services or evidence.

CONTAIN

Containment scope and operational impact

Scope	Potential benefit	Dependency to check
Identity or session	Restricts an abused access route	Emergency access and service identities
Host or workload	Limits communication from the target	Evidence collection and management reachability
Segment or control plane	Restricts multiple movement paths	Critical services and backup access



CONTAIN: RESPONSE TIME

Speedbumps change the outcome

A control does not need to be perfect to slow the attacker, create noise, and buy response time.

SLOW

Separate identity and management paths increase attacker effort.

SIGNAL

Unexpected access creates alerts that matter.

SEGMENT

One compromised tier does not automatically expose every tier.

SURVIVE

Protected backup and recovery infrastructure remain usable.



EIGHT REPEATS (1/2)

The same weaknesses appear in different incidents

Identity and lifecycle

- Identity lifecycle “oops”
- Administrative credentials everywhere
- Password reuse is extremely common
- Lifecycle management is nonexistent



EIGHT REPEATS (2/2)

The same weaknesses appear in different incidents

Exposure, logging and recovery

- Administrative interfaces exposed
- RDP becomes a deployment protocol
- Logging is never configured correctly
- Backup shares the same blast radius



CONTAIN

Island mode: a temporary risk decision

CONDITIONS TO AGREE

Critical function cannot stop immediately.
External connectivity is explicitly controlled.
A business owner accepts residual risk.
A review time and exit plan exist.

LIMITS TO STATE

The system may remain compromised.
Local harmful activity can continue.
Users, media and management can reconnect paths.
Release still requires validation.



CONTAIN

Verification after containment

ACCESS

Test the intended blocked route and inspect other privileged paths.

TELEMETRY

Confirm that monitoring and evidence collection still work as expected.

BUSINESS

Check critical dependencies and document the next review trigger.



DEMO: Containment

Containment and verification

Scope of the restriction, Effect on identities and connectivity ,Verification and service impact

CONTAIN

Exercise: the backup connection

ILLUSTRATIVE TRAINING SCENARIO

The affected server can reach backup management. Isolation would interrupt a critical workload. The current administrator identity is also under review.

YOUR DECISION

Choose the immediate restriction.

Identify the business tradeoff.

Define one verification test and one review trigger.



CONTAIN

Exercise: multiple sites, multiple internet exits

ILLUSTRATIVE TRAINING SCENARIO

Several interconnected sites each have a local internet breakout. We suspect ongoing C2 traffic and want to block all outbound internet access. Coordinating a complete shutdown could take several days.

YOUR DECISION

Block every site's egress, despite the delay?

Block data-center egress and cut site-to-site VPNs first?

Which local exits remain, and how do we verify containment?



CONTAIN

Exercise: ongoing OneDrive data export

ILLUSTRATIVE TRAINING SCENARIO

A binary installed on several workstations is not flagged as malware. It appears to export every OneDrive file it can access to an IP reportedly hosted in a German data center. Intune is unavailable. TeamViewer is available on only some devices.

YOUR DECISION

Power off, disconnect all internet, or block another path?

How do we reach every user, including those offline?

How do we confirm action and that the export has stopped?



CONTAIN

Contain debrief: effect over intent

RESTRICTION

Explain which capability or path the action removes.

DEPENDENCIES

State what could fail and who accepts that risk.

PROOF

Record the observed effect and remaining exposure.



13:45–14:00

Break

Next: Eradicate. What would let the actor return?



ERADICATE

Eradicate: removing access and persistence

BY THE END OF THIS HOUR

Choose rebuild or remediation

Relate the choice to evidence and confidence in integrity.

Plan credential remediation

Include dependencies and alternate access mechanisms.

Set exit evidence

Show why known re-entry paths no longer work.



ERADICATE

Remove capability, not just TA's stuff

- Identify initial access, persistence, privilege escalation, and lateral movement paths.
- Rebuild or clean based on evidence, not hope. Unknown integrity means untrusted.
- Rotate credentials, keys, tokens, certificates, secrets, and service accounts in dependency order.
- Close the control failures that allowed re-entry before production release.



EXIT CRITERIA

The known attacker paths are closed, persistence is removed, trusted administration exists, and monitoring can detect recurrence.

ERADICATE

Rebuild or remediate?

Question	Remediation may be supportable	Rebuild / further investigation
Is scope understood?	Affected changes and access paths are known	Material changes remain unexplained
Can integrity be verified?	Trusted baselines and validation are available	Trust in the platform is missing
Can re-entry be prevented?	Control failures are closed and monitored	The actor may retain an access path



ERADICATE

Credential remediation has dependencies

INVENTORY

Identify accounts, services, keys, certificates and trust relationships in scope.

SEQUENCE

Use a trusted administration path. Plan service impacts and emergency access.

VERIFY

Check for remaining sessions, alternate credentials and renewed access.



ERADICATE: LAUNDRY 2

Instrument, patch, inspect, and clean

- Deploy EDR and logging before expanding connectivity.
- Patch operating systems, applications, agents, and exposed services.
- Hunt for IOCs and persistence identified by the forensic investigation.
- Remove unauthorized accounts, tasks, services, tools, keys, and configuration changes.



NOT ENOUGH

“The malware file is gone” does not prove the system is trustworthy. The attacker’s access path and persistence must also be removed.

The eradication evidence checklist

TECHNICAL EVIDENCE

Known initial access path addressed.
Known persistence removed or rebuilt.
Compromised credentials remediated.
Trusted administration established.

RESIDUAL RISK

Record remaining scope uncertainty.
Name the monitoring owner.
Set a re-investigation trigger.
Approve the handover to recovery.



DEMO: ERADICATE

Password reset

Watch for scope, dependencies, trusted administration and verification.

ERADICATE

Exercise: the clean scan

ILLUSTRATIVE TRAINING SCENARIO

The latest scan reports no detections. An unauthorized scheduled task has been removed. The initial access path and one privileged service credential remain unresolved.

YOUR DECISION

Is eradication complete?

What evidence is missing?

Who owns the remaining work?



ERADICATE

Exercise: unexpected default policy changes

ILLUSTRATIVE TRAINING SCENARIO

Default Domain Policy and Default Domain Controllers Policy appear to have been modified. Should we restore them from backup, or first export the current policies and then reset them to their defaults?

YOUR DECISION

What changed, and what must we preserve first?

Can we trust the backup, and what would a reset change?

Who approves the action, and how do we validate it?



ERADICATE

Exercise: trust after domain controller access

ILLUSTRATIVE TRAINING SCENARIO

The environment has two domain controllers. A threat actor logged on to one of them. We have no evidence of what they did during that session. What would let us trust the domain again?

YOUR DECISION

Install EDR and monitor, or restore from backup?

Rebuild the accessed controller, or both?

Could all domain secrets have been exposed?

If so, what must change before we trust the domain?



ERADICATE

Eradicate debrief: a controlled handover

CAUSE

Address the known route in and the control failure behind it.

CAPABILITY

Remove or rebuild persistence and remediate compromised access.

CONFIDENCE

Document verification, remaining uncertainty and the decision owner.



15:00–15:15

Break

Next: Recover. What must be true before release?



RECOVER

Recover: proof before production

BY THE END OF THIS HOUR

Sequence by dependency

Recover trusted foundations before dependent services.

Validate a restore candidate

Assess incident timing, integrity and business needs.

Authorize production release

Combine technical proof with business acceptance.



RECOVER: IDENTITY

Identity is usually first

If identity is untrusted, every recovered workload inherits that uncertainty.

CLEAN ACCESS

Trusted emergency accounts and administrative workstations.

CONTROL PLANE

Rebuild or recover Tier 0 services and privileged identity.

ROTATE

Revoke sessions and rotate secrets in dependency order.

DELEGATE

Create least-privileged operational administration.

VERIFY

Monitor authentication and privileged actions before expansion.



RECOVER: BACKUP

A successful backup is not automatically safe

The newest restore point may contain the attacker, persistence, or corrupted data.

CAN WE ACCESS IT?

Separate identity, keys, media, software, and documentation.

IS IT INTACT?

Immutable, isolated, monitored, and protected from deletion.

IS IT CLEAN?

Restore points mapped against the incident timeline and evidence.



RECOVER: BACKUP

A successful backup is not automatically safe

The newest restore point may contain the attacker, persistence, or corrupted data.

CAN WE RESTORE FAST ENOUGH?

Measured read, write, dependency, and validation time.

REBUILD?

Would a clean rebuild or redeployment be safer and faster?

DECOMMISSION?

Check business need, dependencies and data retention.

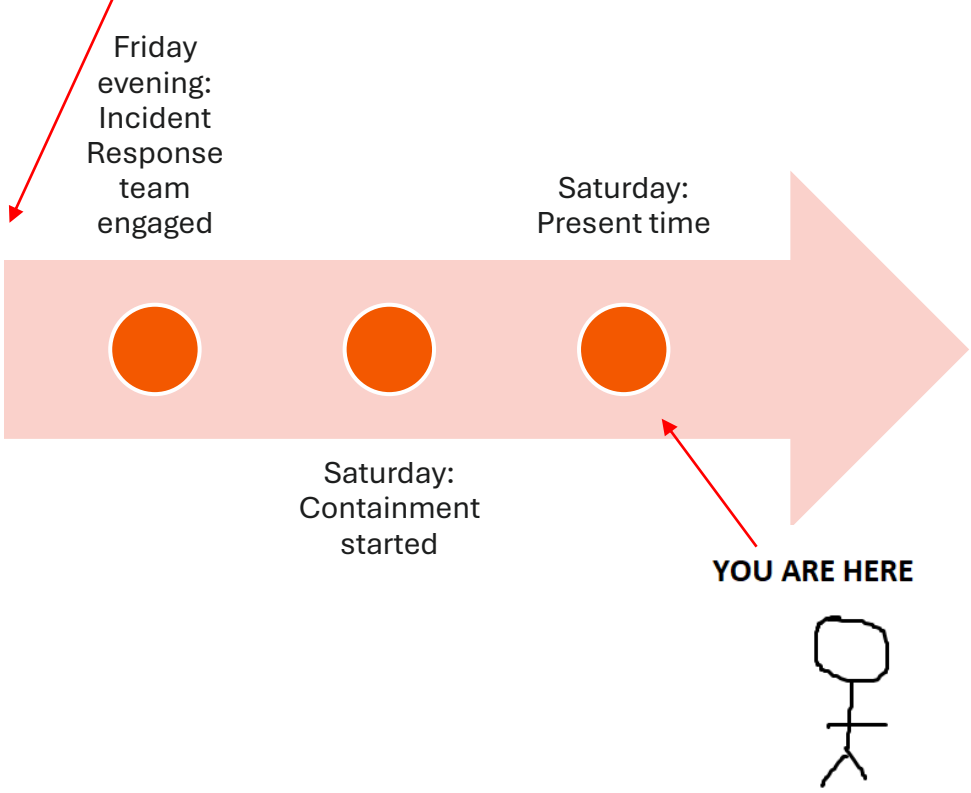


RECOVER: Backup restore points

How much data loss can you accept?

RPO = 5 days?





Threat Actor Initial Access

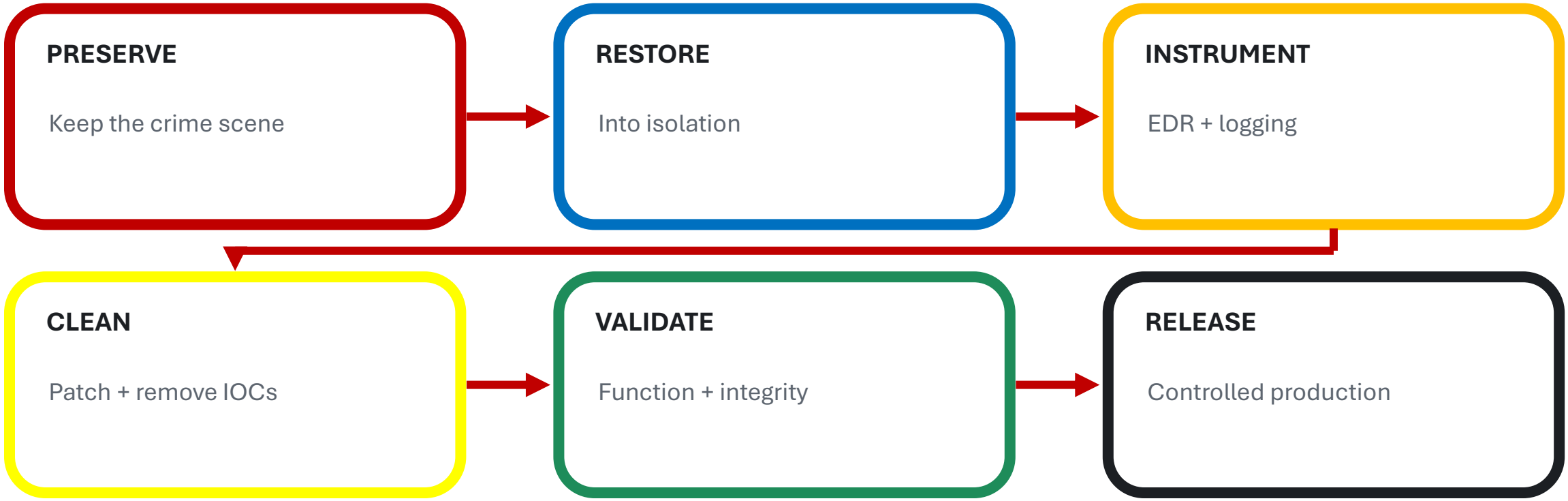
Active Directory breached

RPO ~ 18 hrs?

RECOVER: LAUNDRY PROCESS

Restore is only the beginning

Every restored workload passes through a controlled cleaning and validation pipeline.



Production is a destination, not the cleaning room.

RECOVER: LAUNDRY 1

Preserve and restore into isolation

- Keep original systems and evidence. Never overwrite compromised virtual machines.
- Create enough capacity for both the preserved environment and recovered workloads.
- Restore into a dedicated laundry network with outbound internet blocked by default.
- Use clean identity, clean administration, trusted media, and documented chain of custody.



DESIGN RULE

A restored workload must not be able to reach users, production dependencies, backup infrastructure, or the internet until explicitly authorized.

Validate before release

- Verify application functionality, dependencies, and business transactions.
- Validate data integrity, ownership, permissions, and required recovery point.
- Confirm identity, monitoring, backup, EDR, patching, and administrative controls.
- Release through a limited validation ring with aggressive monitoring and rollback criteria.



TWO SIGN-OFFS

Technical owner: the workload is clean and controlled. Business owner: the service and data are fit for use.

RECOVER: SERVICE ORDER

Recover business capabilities, not a list of servers

Sequence by dependency, business impact, readiness, and restart risk.

FOUNDATION

Identity
DNS / DHCP
Network
Clean administration

PLATFORM

Virtualization
Storage
Backup
Monitoring

BUSINESS SERVICES

Customer operations
ERP / finance
Communication
Industry systems

EXPANSION

Endpoints
Integrations
Analytics
Lower-criticality services



RECOVER: LEARNING LOOP

Recovery must reduce the next incident

Every major recovery decision should create a permanent control improvement.

OBSERVED

What failed or slowed us?

CORRECTED

What did we change during recovery?

ENGINEERED

How do we make the change durable?

REHEARSED

How will we prove it works?



RECOVER

The production release decision

Gate	Evidence to show	Accountable acceptance
Technical readiness	Integrity, monitoring and dependencies validated	Technical service owner
Business readiness	Required transactions and data checked	Business service owner
Controlled release	Limited exposure, monitoring and rollback criteria	Incident / recovery authority



DEMO: RECOVER / 20 MIN

Administrative tiering

Watch for privileged access boundaries and a trusted recovery administration path.

RECOVER

Exercise: the first service release

ILLUSTRATIVE TRAINING SCENARIO

A restored service passes its technical checks. The business owner has not validated transaction totals. Monitoring is enabled, but rollback ownership is unclear.

YOUR DECISION

Would you release it now?

Which evidence is still required?

Name the owner and stop condition.



RECOVER

Exercise: the encrypted sync server

ILLUSTRATIVE TRAINING SCENARIO

Ransomware encrypted the server running identity synchronization on Windows Server 2016. OS support ends in January 2027. The sync version and backup integrity still need verification.

YOUR DECISION

Restore the server and keep using it?

Build and configure a new server from scratch?

Reuse validated configuration from the backup?

What must we verify before sync resumes?



Exercise: the same password everywhere

ILLUSTRATIVE TRAINING SCENARIO

The customer reused the same password across local accounts on multiple computers. The attacker exploited that reuse. Recovery must prevent the same credential from opening every door again.

YOUR DECISION

How will local admin passwords be unique per device?

Who may retrieve it, and when must it rotate?

Which other local accounts need attention?

How will we verify coverage and exceptions?



RECOVER

Exercise: stronger remote access

ILLUSTRATIVE TRAINING SCENARIO

The customer used a username and password for VPN access. Compromised credentials exposed the environment. Remote access must return with stronger authentication and controlled access.

YOUR DECISION

Compare OTP, push, certificates and passkeys.

Which methods resist phishing and credential replay?

Can the VPN use FIDO2 via its identity provider?

How will enrollment and fallback stay secure?



RECOVER

Exercise: rebuilding a flat network

ILLUSTRATIVE TRAINING SCENARIO

All computers shared one subnet before the incident. As services return, the team can rebuild the same network or introduce separation. Which boundaries would reduce the risk of another incident?

YOUR DECISION

Which zones need separation, and why?

Separate identity, management, backup and users?

Where do recovery and untrusted systems belong?

Which flows are allowed, enforced and tested?



RECOVER

Recover debrief: a service you can trust

PROOF

Show technical and business validation, not just a successful restore.

CONTROL

Limit the first release and keep monitoring and rollback ready.

OWNERSHIP

Record who accepts the service and who responds to new evidence.



BARE MINIMUM (1/2)

If you do nothing else, do this

Controls that help us KNOW, ACT, CONTAIN, ERADICATE and RECOVER.

MFA / PASSWORDLESS

Admins and external access

ISOLATE MANAGEMENT

Hypervisor, storage, network, backup

PROTECT BACKUP

Separate identity, immutable, offsite



BARE MINIMUM (2/2)

If you do nothing else, do this

Controls that help us KNOW, ACT, CONTAIN, ERADICATE and RECOVER.

PROTECT LOGS

Central, retained, inaccessible to attacker

ADMIN TIERING

Limit where privileged credentials exist

BREACH MODE

Authority, contacts, offline plans, exercises



TAKEAWAY

Recovery is the moment security becomes business

Know the situation. Act with authority. Contain the spread. Eradicate the attacker. Recover with proof.

KNOW	ACT	CONTAIN	ERADICATE	RECOVER
				

You can troubleshoot later.
You cannot recreate destroyed evidence.

Questions & discussion

Your next incident-readiness improvement

BEFORE YOU LEAVE

Choose one gap exposed by today's case.
Name the owner and first action.
Agree what evidence would show improvement.

BACK AT WORK

Review emergency access and authority.
Rehearse a scoped response decision.
Test recovery and business acceptance together.



Thank You

hello@truesec.com

www.truesec.com

linkedin.com/company/truesec